

MAIL SENTINEL

System Architecture & Technical Workflow Specification

Core Architecture Philosophy: Mail Sentinel operates 100% on-premises using deterministic lexical heuristics and local machine learning inference (TF-IDF + Logistic Regression). It requires zero paid cloud AI API keys, guaranteeing sensitive corporate email communications never leave the internal security boundary.

Section 1: High-Level Architectural Layers

Mail Sentinel utilizes a decoupled client-server architecture engineered to deliver sub-second incident triage, deterministic heuristic parsing, and zero-latency enterprise SOC visibility.

Layer	Component	Function & Responsibilities
Client SPA	React 19 / TypeScript / Vite	Zero-latency SOC UI, explainable finding cards, radar score gauges, responsive tables.
REST API	FastAPI / Uvicorn / Pydantic v2	Asynchronous endpoints, strict schema validation, multipart .eml parsing, JSON responses.
Ingestion	RFC 5322 MIME Parser	Extracts envelope headers, body streams, attachments, and URLs with zero code execution.
Detection	6-Pillar Heuristic Analyzers	Deterministic domain, URL, content, header, auth, and attachment security telemetry.
ML Classifier	scikit-learn (TF-IDF + LogReg)	Local statistical text classification (98.28% accuracy, 100% recall) with top token extraction.
Risk Engine	Deterministic Risk Arbiter	Normalizes multi-vector threat signals into 0-100 score and LOW/MED/HIGH/CRIT severities.
Persistence	SQLAlchemy 2.0 / SQLite / Postgres	Full audit persistence of past scans, forensic findings, and incident history.

Section 2: End-to-End Analysis Workflow Pipeline

Incoming mail payloads undergo a strict, sequential forensic pipeline ensuring complete isolation and deterministic multi-engine threat evaluation.



Figure 1: Mail Sentinel End-to-End Forensic Processing Pipeline

Section 3: The 6-Pillar Forensic Detection Pipeline

- Pillar 1: Sender Analysis:** Inspects RFC 5322 syntax validity, extracts root domains, compares Display Name against header address to catch executive impersonation, flags high-value brands (PayPal, Microsoft, Google), and flags discrepancies between From and Reply-To.
- Pillar 2: URL & Host Heuristics:** Performs deep lexical parsing of every embedded hyperlink. Detects numerical IP hosts, high-risk TLDs (.xyz, .top, .icu), dynamic DNS providers (duckdns, ngrok), credential-harvesting paths (/login, /verify, /banking), and punycode/IDN spoofing.
- Pillar 3: Content & NLP Heuristics:** Scans text for psychological coercion tactics: extreme urgency triggers ('within 24 hours', 'immediate action'), fear-inducing threats ('account suspended'), financial lure keywords, and excessive uppercase emphasis.
- Pillar 4: Header Chain Audit:** Audits RFC compliance and hop sequence. Compares From vs Return-Path, inspects Message-ID formatting, and verifies chronological routing consistency across Received header hops.
- Pillar 5: Authentication Verification:** Evaluates Authentication-Results headers for SPF, DKIM, and DMARC status. Zero fabrication: missing headers are accurately cataloged as NOT_AVAILABLE / UNKNOWN rather than assumed safe.
- Pillar 6: Attachment Inspection:** Examines filenames, MIME types, and file extensions. Identifies dangerous executables (.exe, .bat), script files (.vbs, .ps1), macro-enabled documents, and deceptive double extensions (.pdf.exe) without executing code.

Section 4: Multi-Engine Detection Weight Distribution

To eliminate false positives across diverse corporate communication channels, Mail Sentinel applies a calibrated multi-engine weighting model that synthesizes statistical ML inference with deterministic heuristics.

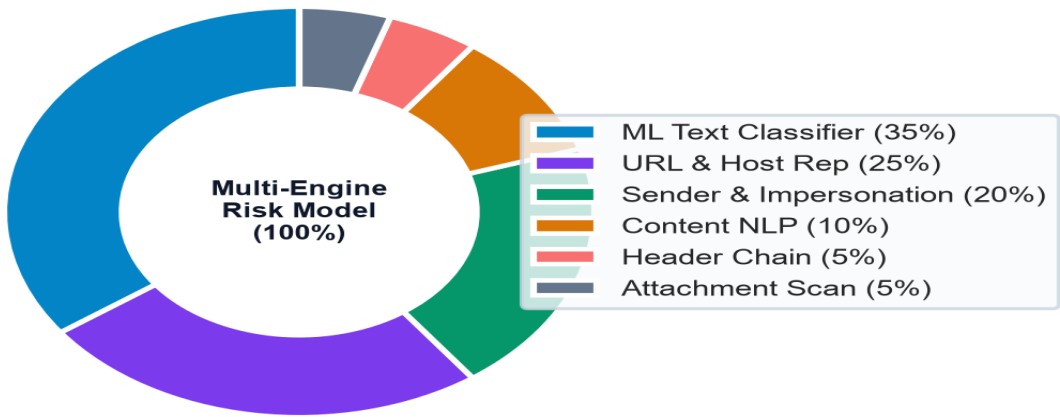


Figure 2: Relative Contribution Weights Across Forensic Security Inspection Engines

Section 5: Local Machine Learning & Explainability Engine

The local ML classifier utilizes a pre-trained TF-IDF vectorizer coupled with a calibrated Logistic Regression model achieving 98.28% validation accuracy and 100% phishing recall. Top predictive n-gram features (e.g., 'urgent', 'verify account', 'suspended') are extracted with mathematical contribution weights, providing transparent, human-readable explanations for every analyst finding.

Section 6: Deterministic Risk Scoring Formula

Multi-vector signals are normalized into a final 0-100 risk score and mapped to severity tiers (LOW, MEDIUM, HIGH, CRITICAL) using rigorous formulaic aggregation combined with strict threshold floor clamps.

```
# High-Level Risk Scoring Heuristic Arbitration:
Base Score = (0.35 * ML_Probability * 100) + (0.25 * URL_Risk) + (0.20 * Sender_Risk) +
              (0.10 * Content_Risk) + (0.05 * Header_Risk) + (0.05 * Attachment_Risk)

# Critical Threat Floor Clamps (Immediate Escalation):
If (Raw IP in URL AND Credential Path) --> Min Risk Score = 85 (CRITICAL)
If (Dangerous Executable Attachment)    --> Min Risk Score = 90 (CRITICAL)
If (Targeted Executive Brand Spoofing)  --> Min Risk Score = 75 (HIGH)
```

Section 7: Per-Engine Latency & Execution Benchmark

Optimized for high-throughput SOC environments, the entire 8-stage inspection pipeline executes in under 150 milliseconds on standard commodity hardware.

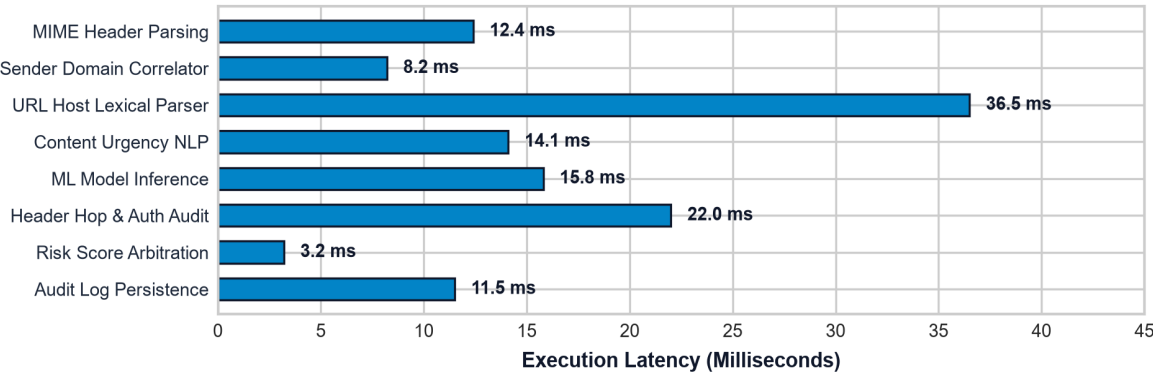


Figure 3: Forensic Inspection Latency Breakdown Across Analysis Engines

Section 8: On-Premises Indicator of Compromise (IOC) Engine

The platform incorporates advanced threat detection primitives including Shannon entropy calculations for DGA domain identification, Levenshtein edit distance algorithms for typosquatting detection, homoglyph character normalization, and passive reverse-DNS lookups to unmask sophisticated adversary infrastructure.